

CONSTRUCTION OS

PRD_10

Project Interaction with Company Members

Full Stack Engineering Specification

DOCUMENT STATUS	Build-ready baseline
PRODUCT AREA	Projects / Company Collaboration / Access Control
SCOPE OWNER	Product Management
VERSION	1.0
DATE	03 August 2026

1. Document Purpose

PRD_10 defines how a Project interacts with all active internal company members. It establishes company-wide project discovery, opening rights, participation boundaries, sensitive-data protection, role-aware visibility, and the technical contract between frontend, backend, permissions, audit, and notification services.

Confirmed product decision

Every active company member can see and open every project in the company. Sensitive sections and records remain protected by existing role-based and record-level permissions.

This PRD is intentionally limited to project-to-company-member interaction. It does not define project templates, WBS, stage gates, folder structures, change orders, RFIs, submittals, or cost-control workflows.

2. Product Principles

- 1 Project visibility is company-wide. A project must not become hidden merely because a user is not assigned to it.
- 2 Opening a project is not equivalent to unrestricted access. Sensitive sections remain protected by permissions.
- 3 Least privilege remains the default. Visibility to a project shell does not grant edit, approve, download, financial, HR, legal, or contract rights.
- 4 Permissions are evaluated at request time. Frontend hiding is not a security boundary.
- 5 All access-sensitive actions are auditable. Permission grants, revocations, denials, and privileged actions must be traceable.
- 6 Existing governance remains authoritative. PRD_10 extends project visibility but does not weaken rules established in prior PRDs.

3. Scope

3.1 In scope

- Company-wide project listing and search.
- Opening the project overview by any active internal company member.
- Project page behavior for assigned and unassigned members.
- Section-level and record-level permission enforcement.
- Role-aware project navigation and disabled/hidden states.
- Participation indicators, member lists, departments, responsibilities, and activity visibility.
- Audit, analytics, caching, API, frontend state, and acceptance requirements.
- Corporate-group context as inherited from prior access-control rules.

3.2 Out of scope

- Project creation templates, WBS, stage gates, fixed folder structures, and project setup design.
- Change Orders / Project Variations.
- RFI and Technical Query workflows.

- Submittals and Material Approval.
- Detailed cost-control, procurement, site-management, or document-control workflows.
- Client portal access. Clients do not receive direct platform access under the current product scope.
- External contractor behavior beyond permissions already defined in previous PRDs.

4. Definitions

Term	Definition
Company member	An active internal user account belonging to the current legal company context.
Assigned member	A user explicitly assigned to the project, a project role, a department contribution, a task, a review, an approval, or another governed project relationship.
Unassigned member	An active company member with no explicit project participation relationship.
Project shell	The non-sensitive, company-visible project identity and overview available to every active company member.
Sensitive section	A project area protected by role-based or record-level permissions, such as Finance, HR, Legal, contracts, private documents, restricted approvals, or controlled records.
Permission context	The combination of tenant, company, corporate group, active role, department, project assignment, record relationship, and explicit grants/revocations used to authorize a request.

5. Primary User Experience

5.1 Company Projects index

Every active company member can access the Projects index for the current company context. The index must show every non-deleted project that the user is entitled to discover under corporate-group rules.

- Project name and project code.
- Primary image or neutral placeholder.
- Location, client display name when not restricted, and general project category.
- Project Manager and involved departments when permitted.
- High-level project status using platform-standard status colors.
- User relationship badge: Assigned, Department Involved, Task Contributor, Reviewer, Approver, Watcher, or Unassigned.
- Last permitted activity timestamp. Restricted activity must not leak through metadata.
- Search and filters by name, code, location, department, Project Manager, status, and relationship.

5.2 Opening a project

Opening a project loads a common project shell. The shell must never fail solely because the user is unassigned. Each section is then authorized independently.

- Allowed section: rendered normally with actions limited by permission.
- Discoverable but restricted section: rendered as a locked navigation item with a short reason, without sensitive counts, previews, filenames, totals, or names.
- Non-discoverable sensitive section: omitted entirely when revealing its existence would disclose protected information.
- Revoked access: immediately removed on the next authorization check; cached content must be invalidated.

V1 default for unassigned members

Because no broader participation action has yet been approved, an unassigned member is read-only for permitted project-shell information. The user cannot comment, upload, assign, approve, edit, request access, or create project records unless another rule grants that capability. This follows the established deny-by-default security model and may be expanded in a later PRD.

5.3 Project overview visible to all company members

Component	Company-wide visibility
Project identity	Name, code, general category, non-sensitive image, and location.
General status	Platform-standard project status. No detailed financial or contractual meaning.
Public internal summary	A company-safe project summary explicitly marked as visible to all internal members.
Leadership	Project Manager and Project Director, unless a governance rule restricts a person record.

Component	Company-wide visibility
Involved departments	Department names only. Does not grant access to department-sensitive records.
General timeline	High-level start and target completion dates when not contractually restricted.
User relationship	The current user sees why they are or are not connected to the project.

6. Permission Model

Authorization must be implemented server-side using layered RBAC and record-level access rules. The project-level discover/open permission is separate from section and action permissions.

Capability	Who	Rule
Discover project	All active company members	Shows the project in list/search without exposing sensitive metadata.
Open project shell	All active company members	Loads the common project overview and permitted navigation.
View general overview	All active company members	Read-only company-safe content.
View project tasks	Per task/project permissions	Unassigned users must not receive task details by default.
View general documents	Per document and folder permissions	Controlled or sensitive documents remain restricted.
View Finance	Finance, Admin, Owner, and explicit permitted roles	Project visibility never grants financial access. PM limits remain as previously defined.
View HR	HR, Admin, Owner, and narrowly authorized superior views	Salary, disciplinary, and private HR data remain protected.
View Legal / contracts	Per contract involvement and explicit grants	Exact-contract access does not expose linked Finance or HR records.
Edit / approve / delete	Existing module and record rules	Opening the project does not create action rights.
Admin / Owner visibility	Existing governance	Owner and Admin powers remain subject to prior PRDs, including owner protections.

6.1 Authorization evaluation order

- 1 Validate authenticated session and active account.
- 2 Resolve tenant, legal company, corporate-group context, and current company switcher state.
- 3 Confirm project belongs to a visible company context and is not deleted or quarantined.
- 4 Grant project discovery and shell opening to active internal company members.
- 5 Resolve active role, department, project assignment, task or record relationship, explicit grants, and explicit revocations.
- 6 Apply deny rules for sensitive modules and data classes.
- 7 Return the minimum permitted payload and permitted actions.
- 8 Write audit events for privileged, denied, granted, revoked, download, approval, and destructive actions as required.

7. User Roles and Expected Behavior

User type	PRD_10 behavior
Unassigned company member	Can discover and open the project shell. Can read only company-safe overview data. No implicit participation rights.
Assigned project member	Receives access according to assignment, project role, department involvement, tasks, records, and explicit grants.
Department member	Access is determined by department involvement rules. Department membership alone does not automatically expose all sensitive project records.
Department Manager	Receives management capabilities only where established by module rules; may manage certain department-based access under prior PRDs.
Project Manager	Manages permitted project operations but retains limited Finance visibility as previously defined.
HR user	Can access HR-governed project records according to HR role; cannot infer access to unrelated legal or financial records.
Finance user	Can access Finance-governed project records according to Finance permissions. Creative role theme may change interface, not authorization.
Legal user	Can access governed legal and contract records according to exact record involvement and grants.
Company Admin	Uses the broad company-level powers defined in prior PRDs, excluding protected Owner actions.
Company Owner	Retains highest company authority under prior governance rules.
Group-level user	Project visibility follows inherited parent/child company access rules and any valid child-company restriction.
External contractor	Not treated as an internal company member. Sees only explicitly assigned contract, document, task, or project content under prior external-access rules.

8. Functional Requirements

ID	Requirement
PRD10-FR-001	The Projects index shall include every visible project in the current company context for every active internal company member.
PRD10-FR-002	Every active internal company member shall be able to open the project shell.
PRD10-FR-003	The system shall authorize every project section and record independently from project-shell access.
PRD10-FR-004	The API shall return only permitted fields, records, counts, aggregates, previews, and actions.
PRD10-FR-005	Restricted data shall not be exposed through search, filters, activity feeds, counts, notifications, exports, URLs, errors, or cached responses.
PRD10-FR-006	The project page shall clearly distinguish permitted, locked, and non-discoverable sections.
PRD10-FR-007	An unassigned member shall be read-only for the permitted project shell in V1.
PRD10-FR-008	Role or department theme changes shall not change permissions or returned data.
PRD10-FR-009	Explicit revocation shall override inherited or assignment-based access where prior rules permit revocation.
PRD10-FR-010	Permission changes shall invalidate relevant authorization and response caches promptly.

ID	Requirement
PRD10-FR-011	Project list and search results shall show the current user relationship without revealing restricted relationships.
PRD10-FR-012	Deleted projects shall not appear to ordinary users; restoration and deletion follow prior governance rules.
PRD10-FR-013	All endpoints shall be tenant-safe and company-context-safe. Object IDs alone must never bypass authorization.
PRD10-FR-014	Sensitive exports and downloads shall use the same permission checks as on-screen access.
PRD10-FR-015	Mobile and desktop clients shall apply the same authorization contract and display equivalent restricted states.

9. Frontend Specification

9.1 Routes

View	Suggested route	Behavior
Projects index	/companies/{companyId}/projects	Company-wide discoverable project list.
Project shell	/companies/{companyId}/projects/{projectId}	General project overview.
Project section	/companies/{companyId}/projects/{projectId}/{section}	Section-specific permission check.
Record deep link	Module-specific	Must validate project, section, record, and action permissions independently.

9.2 Project shell state contract

The frontend should receive a project-shell payload containing company-safe data plus a capability map. It must not reconstruct permissions from role names.

Example response shape:

```
{
  "project": { "id": "...", "name": "...", "code": "...", "status": "...", },
  "relationship": "UNASSIGNED",
  "capabilities": {
    "viewOverview": true,
    "viewTasks": false,
    "viewDocuments": false,
    "viewFinance": false,
    "viewLegal": false,
    "comment": false,
    "edit": false
  },
  "navigation": [ ... ]
}
```

9.3 Required UI states

- Loading skeleton without temporary exposure of restricted content.
- Project not found.
- Project exists but current company context is invalid.
- Project shell allowed with one or more locked sections.
- Record access revoked while page is open.
- Account deactivated or company membership removed.

- Permission service temporarily unavailable: fail closed for sensitive content.
- Deep link to restricted record: show neutral access-denied state without revealing record metadata.

10. Backend and API Specification

10.1 Services

Component	Responsibility
Project Query Service	Lists discoverable projects and returns the company-safe project shell.
Authorization Service	Evaluates tenant, company, role, department, project, record, action, grant, and revocation context.
Membership Service	Resolves active internal company membership and corporate-group access.
Audit Service	Stores immutable security and business-action events according to prior audit rules.
Notification Service	Emits only notifications the recipient is permitted to understand and open.
Search Indexer	Indexes company-safe fields globally and sensitive fields only inside permission-aware search partitions or post-filtering.

10.2 Recommended endpoints

Method	Endpoint	Purpose
GET	/companies/{companyId}/projects	List all discoverable projects with safe filters and relationship badges.
GET	/companies/{companyId}/projects/{projectId}/shell	Return project shell, permitted navigation, and capabilities.
GET	/companies/{companyId}/projects/{projectId}/sections/{sectionKey}	Return only permitted section data.
GET	/companies/{companyId}/projects/{projectId}/members	Return member data permitted to the requester.
GET	/companies/{companyId}/projects/{projectId}/activity	Return a permission-filtered activity feed.
POST	/authorization/evaluate	Internal service call or library contract for action evaluation.

10.3 Security requirements

- Use opaque identifiers or UUIDs; never rely on sequential IDs as a control.
- Validate tenant and company ownership for every project and related record.
- Reject IDOR attempts with neutral responses.
- Never trust client-provided role, company, department, project relationship, or capability values.
- Apply field-level serialization for sensitive mixed objects.
- Filter aggregates and counts. A hidden record must not be discoverable through a count difference.
- Use short-lived permission caches keyed by user, active role, company, project, record class, and permission version.
- Increment permission version or publish invalidation events after assignment, revocation, employment, role, or company-context changes.
- Exports, background jobs, webhooks, emails, and push notifications must re-evaluate authorization at execution time where appropriate.

11. Data Model Additions

Entity / field	Purpose
project_visibility_policy	Project-level policy. V1 value is COMPANY_INTERNAL for every normal project.
project_safe_profile	Company-wide fields intentionally approved for the project shell.
project_membership	Explicit project relationship: user, role, department, responsibility, source, start/end, status.
project_capability_override	Explicit grant or revocation where prior governance allows it.
project_permission_version	Monotonic version used to invalidate caches and stale client state.
project_access_audit	Security-relevant grants, revocations, denials, privileged views, downloads, and changes.

Existing task, document, contract, finance, HR, department, company, group, and user-role models remain authoritative. Do not duplicate module permissions inside the Project entity.

12. Activity, Notifications, and Search

12.1 Activity feed

The project activity feed is permission-filtered per user. A company-wide project shell does not justify a company-wide raw activity feed.

- General company-safe milestones may appear to all members when explicitly marked internal-public.
- Task, contract, finance, HR, legal, document, and approval activity appears only to users authorized for the originating record.
- Redacted placeholders should not be used when the placeholder itself would disclose sensitive activity.
- Activity entries must link only to records the user can currently open.

12.2 Notifications

- Project existence alone does not subscribe every company member to notifications.
- Notifications follow assignment, task, project role, department, watcher, workflow, red-flag, approval, and module rules.
- A notification payload must not contain restricted titles, amounts, filenames, reasons, or person details.
- When access is revoked, unopened notification deep links must fail safely.

12.3 Search

- Global search may return the company-safe project shell to every active company member.
- Sensitive project records require permission-aware indexing or server-side post-filtering before results are returned.
- Search snippets must be generated only from fields visible to the requester.
- Autocomplete and result counts must not leak restricted records.

13. Audit and Observability

- Record project permission grants, revocations, role changes, company membership changes, privileged exports, downloads, approvals, deletions, and denied access attempts according to risk level.
- Audit entries include actor, effective user during impersonation, company, project, record where applicable, action, result, timestamp, source IP/device metadata where permitted, and correlation ID.
- Admin impersonation must preserve both Admin identity and impersonated employee identity.
- Audit records remain immutable and searchable; Admin may archive but not alter or permanently delete them under prior PRDs.
- Operational metrics should include project-list latency, shell latency, authorization latency, denial rate, stale-cache incidents, and forbidden-data exposure tests.

14. Non-Functional Requirements

Category	Requirement
Performance	Projects index p95 <= 1.5 seconds for standard company datasets; project shell p95 <= 1.2 seconds excluding heavy module data.
Scalability	Pagination and indexed filtering are mandatory. Do not load all project members, tasks, or documents with the shell.
Security	Server-side authorization, tenant isolation, field-level filtering, deny by default, and IDOR protection.
Consistency	Permission changes should become effective across interactive clients within 60 seconds, with immediate effect on fresh requests where possible.
Availability	If authorization dependencies fail, sensitive sections fail closed while safe project-shell availability may continue only from verified safe data.
Accessibility	Keyboard navigation, visible focus, accessible lock states, semantic headings, and contrast-compliant role themes.
Responsive UX	Equivalent permissions and capabilities on desktop, tablet, and mobile.
Localization	English and Albanian UI strings. Avoid embedding permission text in backend business logic where localization is required.
Time and locale	Use user locale, EU number conventions, and user-selected time/calendar preferences established in prior PRDs.

15. Acceptance Criteria

- 1 AC-01: Given an active unassigned internal member, when the user opens the Projects index, then every non-deleted project in the current company context is discoverable.
- 2 AC-02: Given an active unassigned internal member, when the user opens a project, then the project shell loads successfully with company-safe overview data.
- 3 AC-03: Given an unassigned member without Finance permission, when the project contains budgets or payments, then no amount, count, status detail, export, search result, notification, or API field exposes that data.

- 4 AC-04: Given a member with exact-contract access, when the user opens the project, then the permitted contract is accessible but unrelated contracts, Finance, HR, and internal legal records remain restricted.
- 5 AC-05: Given a permission revocation, when the user refreshes or requests new data, then revoked data and actions are unavailable and relevant caches are invalidated.
- 6 AC-06: Given a copied deep link to a restricted record, when an unauthorized user opens it, then the system returns a neutral denied state without metadata leakage.
- 7 AC-07: Given a user changes active role and Creative User Type Theme, then navigation may change substantially, but backend capabilities and data remain determined by authorization rules.
- 8 AC-08: Given a group-level user switches child-company context, then project discovery follows inherited group rules and valid child-company restrictions.
- 9 AC-09: Given an external contractor account, when the contractor uses the Projects index, then internal company-wide visibility is not granted; only explicitly assigned content is available.
- 10 AC-10: Given a project-shell API response, then it contains only company-safe fields and an explicit capability map; the frontend does not infer rights from role labels.
- 11 AC-11: Given permission-service degradation, then sensitive sections fail closed and no stale sensitive data is rendered from an unverified cache.
- 12 AC-12: Given an Admin impersonates an employee and opens a project, then the audit trail records both the Admin actor and effective employee context.

16. Engineering Delivery Checklist

Workstream	Required delivery
Backend	Project list/shell endpoints; authorization middleware; field serializers; cache versioning; audit hooks; tests for tenant isolation and IDOR.
Frontend	Projects index; project shell; capability-based navigation; lock/deny/error states; responsive layout; no role-name permission assumptions.
Database	Safe profile fields; membership/relationship model review; permission version; indexes; audit linkage.
Search	Safe project index; permission-aware sensitive search; snippet and count leakage tests.
QA	Role matrix, assigned/unassigned flows, revoked access, group contexts, impersonation, deep links, exports, mobile, cache invalidation.
Security	Threat model; IDOR tests; tenant boundary tests; field leakage tests; notification/search/export review.
DevOps	Permission and denial metrics; correlation IDs; cache invalidation event monitoring; safe rollback plan.

17. Deferred Decisions

Not decided in PRD_10

Whether an unassigned company member may comment, report an issue, request participation, or request access from inside the project. V1 remains read-only for the permitted project shell until a later PRD explicitly expands these capabilities.

- Detailed Team Availability membership rules remain deferred from PRD_9.
- Change Orders / Project Variations remain deferred.
- RFI and Technical Query Management remain deferred.
- Submittals and Material Approval remain deferred.
- Project setup, WBS, stage gates, and templates must be handled in separate PRDs.

18. Final Build Rule

Authoritative implementation statement
Every active internal company member can discover and open every project in the current company context. The project shell is company-wide; project data is not. Every section, record, field, count, action, export, notification, search result, and deep link must continue to obey its own server-side permissions.